Northfield University Office of Information Technology

Cybersecurity Incident Response Plan

Policy Number: 2026-SEC-01 **Version:** 5.0 **Effective Date:** July 1, 2026 **Last Revised:** May 15, 2026 **Document Owner:** Director of Information Security **Approved By:** Chief Information Officer; University Risk Management Committee **Review Cycle:** Annual (next review: July 2027)

1.0 Purpose and Scope

1.1 Purpose

This Cybersecurity Incident Response Plan ("the Plan") establishes the procedures, roles, and responsibilities for detecting, reporting, containing, eradicating, and recovering from cybersecurity incidents affecting Northfield University information systems, networks, and data assets. The Plan is designed to minimize damage to university operations, protect sensitive data, ensure regulatory compliance, and facilitate timely restoration of services.

1.2 Scope

This Plan applies to all cybersecurity incidents involving Northfield University information technology resources, including but not limited to:

- University-owned servers, workstations, and network infrastructure
- Cloud-hosted services and applications managed under university contracts
- University data classified at any level under the *Data Classification and Handling Policy (2026-GOV-03)*
- Personally owned devices connected to university networks (under the *Acceptable Use Policy, 2026-GOV-01*)
- Third-party vendor systems that process, store, or transmit university data

All members of the university community—including faculty, staff, students, contractors, and affiliates—are required to comply with this Plan. Failure to comply may result in disciplinary action as outlined in the *Acceptable Use Policy* and applicable Human Resources policies.

1.3 Regulatory Framework

This Plan has been developed in accordance with the following regulatory requirements and industry frameworks:

- **NIST SP 800-61 Rev. 2** – Computer Security Incident Handling Guide
- **FERPA** – Family Educational Rights and Privacy Act
- **HIPAA** – Health Insurance Portability and Accountability Act (for covered health data)
- **GLBA** – Gramm-Leach-Bliley Act (for financial data)
- **PCI DSS v4.0** – Payment Card Industry Data Security Standard
- **New York State Information Security Breach and Notification Act (General Business Law § 899-aa)**

2.0 Incident Classification and Reporting

2.1 Incident Reporting Requirements

All suspected cybersecurity incidents must be reported to the **Cybersecurity Incident Response Team (CSIRT)** immediately. For **Level 4 (Restricted) data breaches**, the initial report must be filed within **one (1) hour** of discovery. For incidents involving Level 3 data or below, the report must be filed within **24 hours**. Reports are submitted through the IT Security Incident Portal or by calling the CSIRT emergency hotline at **(555) 314-CSRT (2778)**.

Incident reports must include the following information, to the extent known at the time of reporting:

- **Date and time** of discovery

- **Reporter's name**, department, and contact information
- **Description** of the suspected incident, including affected systems or data
- **Indicators of compromise (IOCs)**, such as suspicious IP addresses, file hashes, or phishing emails
- **Actions already taken** (e.g., system isolation, password changes)
- **Estimated scope** of impact (number of users, records, or systems affected)

Faculty and staff who become aware of a potential incident through a student report or third-party notification are equally obligated to file a report. Delays in reporting may increase the severity of an incident and may constitute a policy violation subject to sanctions under the *Acceptable Use Policy (2026-GOV-01)*.

2.2 Incident Severity Classification

All reported incidents are classified by the CSIRT using a four-tier severity model. The severity level determines the response timeline, resource allocation, and escalation requirements.

Severity	Classification	Description	Response Time	Examples
Sev-1	**Critical**	Active, widespread compromise of Level 4 data or critical infrastructure; imminent threat to university operations	Immediate (within 15 minutes of classification)	Ransomware affecting enterprise systems; active exfiltration of SSNs or financial records; compromise of identity management systems
Sev-2	**High**	Confirmed compromise of sensitive data or significant system disruption with limited scope	Within 1 hour	Unauthorized access to research data; targeted phishing campaign with confirmed credential theft; DDoS attack on primary web services
Sev-3	**Moderate**	Suspicious activity or minor security event requiring investigation; no confirmed data loss	Within 4 hours	Malware detected on individual workstation; unauthorized access attempt blocked by controls; policy violation with security implications
Sev-4	**Low**	Routine security event or informational alert; minimal risk	Within 24 hours	Failed login attempts below threshold; spam or low-confidence phishing email; routine vulnerability scan findings

The CSIRT Lead Analyst may reclassify an incident at any time as new information becomes available. Reclassification to a higher severity level triggers the corresponding escalation procedures described in Section 4.0.

3.0 CSIRT Organization

3.1 CSIRT Leadership and Structure

The CSIRT is led by the **Director of Information Security, Dr. Patricia Okonkwo**. Dr. Okonkwo reports directly to the Chief Information Officer and serves as the university's primary liaison to federal cybersecurity agencies. The CSIRT emergency hotline is available 24/7 at **(555) 314-2778**. For non-emergency consultations, contact the CSIRT office at **csirt@northfield.edu** during business hours (Monday–Friday, 8:00 AM – 5:00 PM ET).

The CSIRT operates as a dedicated unit within the Office of Information Technology and is organized into the following functional roles:

Role	Responsibility	Primary Contact
CSIRT Director	Overall incident command; executive communication; regulatory liaison	Dr. Patricia Okonkwo
Lead Incident Analyst	Triage and classification; technical investigation coordination	Marcus Chen, Senior Security Analyst
Forensics Specialist	Digital evidence preservation and analysis; chain-of-custody management	Dr. Anika Patel
Network Security Engineer	Network containment; traffic analysis; firewall and IDS/IPS management	James Whitfield
Systems Security Engineer	Endpoint containment; malware analysis; system restoration	Keisha Robinson
Communications Coordinator	Internal and external communications; media relations support	Linda Vasquez
Legal and Compliance Liaison	Regulatory notification requirements; legal review of incident data	Office of General Counsel (assigned per incident)

3.2 Extended Response Team

For Sev-1 and Sev-2 incidents, the CSIRT Director may activate the Extended Response Team, which includes representatives from:

- **Office of General Counsel** – Legal guidance, regulatory notification obligations, law enforcement coordination
- **University Communications** – Media inquiries, public statements, campus-wide notifications
- **Human Resources** – Incidents involving employee misconduct or insider threats
- **Office of the Registrar** – Incidents involving student educational records (FERPA-protected data)
- **Research Compliance Office** – Incidents involving sponsored research data or export-controlled materials
- **Facilities and Physical Security** – Incidents with physical security dimensions (e.g., unauthorized data center access)
- **External Partners** – Managed Security Service Providers (MSSPs), law enforcement, and federal agencies (FBI, CISA) as appropriate

3.3 On-Call Rotation

The CSIRT maintains a 24/7 on-call rotation to ensure immediate response capability. The on-call analyst serves as the initial point of contact for all incidents reported outside of business hours. On-call schedules are published monthly on the CSIRT internal SharePoint site and are accessible to the IT Service Desk for routing purposes.

- **On-call shift hours:** 5:00 PM – 8:00 AM ET (weekdays), 24 hours (weekends and university holidays)
- **Maximum on-call response time:** 15 minutes for Sev-1; 30 minutes for Sev-2
- **Escalation:** If the on-call analyst does not respond within the designated time, the IT Service Desk escalates directly to the CSIRT Director

4.0 Escalation Procedures

4.1 Internal Escalation Matrix

Escalation is triggered automatically based on severity classification and elapsed time. The following matrix defines the escalation path:

Elapsed Time	Sev-1 Action	Sev-2 Action	Sev-3 Action	Sev-4 Action
0–15 min	CSIRT Director notified; all CSIRT activated; Extended Response Team on standby	Lead Analyst assigns investigation team	On-call analyst begins triage	Logged for review
15–60 min	CIO briefed; Extended Response Team activated; university leadership notified	CSIRT Director briefed; additional resources allocated	Lead Analyst review	—
1–4 hours	University President and Board Risk Committee notified; external counsel engaged	CIO briefed if unresolved; Extended Response Team considered	CSIRT Director notified if scope expands	On-call analyst reviews
4–24 hours	Regulatory notification assessment begins; external forensics firm engaged if needed	Extended Response Team activated if unresolved	Reassessment of severity	—
24+ hours	Ongoing executive briefings every 4 hours; regulatory filings initiated as required	Ongoing CSIRT Director briefings every 8 hours	Escalate to Sev-2 if unresolved	Close or escalate

4.2 External Escalation and Notification

Certain incidents require notification to external parties. The CSIRT Director, in coordination with the Office of General Counsel, determines when external notification is required.

Mandatory External Notifications:

- **Law Enforcement:** Required for any incident involving suspected criminal activity, including unauthorized network intrusion, ransomware, intellectual property theft, or threats of violence. Contact is made through the Office of General Counsel or directly to the FBI Cyber Division and/or local law enforcement.
- **Regulatory Bodies:** Required when a breach involves protected data categories:
- **FERPA:** U.S. Department of Education notification within 72 hours for breaches involving student records
- **HIPAA:** HHS Office for Civil Rights notification within 60 days for breaches affecting 500+ individuals; individual notification without unreasonable delay
- **PCI DSS:** Payment card brand notification within 24 hours; engagement of PCI Forensic Investigator (PFI)
- **State Breach Notification:** New York Attorney General notification as required by General Business Law § 899-aa
- **Affected Individuals:** Notification to individuals whose personal data was compromised, as required by applicable law. Notification content and timing are coordinated with General Counsel.
- **CISA (Cybersecurity and Infrastructure Security Agency):** Voluntary reporting for significant incidents; mandatory reporting for incidents affecting critical infrastructure per CIRCIA requirements.

4.3 Communication Protocols During Active Incidents

During an active Sev-1 or Sev-2 incident, the following communication protocols are in effect:

- **Incident War Room:** A dedicated physical or virtual war room is established. All CSIRT communications are centralized through this channel.
- **Secure Communications:** All incident-related communications must use encrypted channels. University email may be compromised during an active incident; the CSIRT maintains a secondary encrypted communication platform (Signal-based) for this purpose.
- **Status Updates:** The Communications Coordinator issues internal status updates at defined intervals (every 1 hour for Sev-1, every 4 hours for Sev-2) via the university's emergency notification system.
- **Media Inquiries:** All media inquiries are directed to University Communications. No CSIRT member or university employee may speak to the media about an active incident without explicit authorization from the CSIRT Director and University Communications.
- **Documentation:** All actions, decisions, and communications during an incident are logged in the incident management system with timestamps. This log serves as the official record for post-incident review and regulatory compliance.

5.0 Incident Response Lifecycle

The CSIRT follows a structured incident response lifecycle based on the NIST SP 800-61 framework. Each phase has defined objectives, activities, and deliverables.

5.1 Phase 1: Detection and Identification

Objective: Confirm whether a reported event constitutes a cybersecurity incident and determine its scope.

Activities:

1. **Initial Triage:** The receiving analyst reviews the incident report, gathers preliminary information, and makes an initial severity determination within 15 minutes of receipt.
2. **Validation:** Correlate reported indicators with security monitoring data (SIEM alerts, IDS/IPS logs, endpoint detection and response (EDR) telemetry, network flow data).
3. **Scope Assessment:** Determine the number and type of affected systems, users, and data classifications. Reference the *Data Classification and Handling Policy (2026-GOV-03)* to determine the sensitivity level of potentially compromised data.
4. **Classification:** Assign a formal severity level per Section 2.2 and initiate the corresponding response procedures.

Deliverables: Incident ticket created in the incident management system; severity classification assigned; initial stakeholders notified per escalation matrix.

5.2 Phase 2: Containment

Objective: Limit the spread and impact of the incident while preserving evidence for forensic analysis.

Short-Term Containment (Immediate Actions):

- Isolate compromised systems from the network (disable network ports, modify firewall rules, quarantine endpoints via EDR)
- Disable compromised user accounts and revoke active sessions through the *Identity and Access Management (IAM) Policy (2026-SEC-02)*
- Block malicious IP addresses, domains, and file hashes at the perimeter
- Preserve volatile evidence (memory dumps, running processes, network connections) before any system changes

Long-Term Containment (Stabilization):

- Deploy temporary fixes or patches to prevent re-exploitation
- Implement enhanced monitoring on affected segments
- Stand up clean replacement systems if production systems must remain offline
- Coordinate with third-party service providers to contain incidents affecting cloud or vendor-hosted environments

Evidence Preservation Requirements:

All containment actions must be performed in a manner that preserves digital evidence. The Forensics Specialist oversees evidence handling in accordance with the following standards:

- Forensic images of affected systems are created before remediation begins
- Chain-of-custody documentation is maintained for all evidence
- Evidence is stored in a secured, access-controlled forensic repository
- All evidence handling complies with Federal Rules of Evidence standards to support potential legal proceedings

5.3 Phase 3: Eradication

Objective: Remove the root cause of the incident and eliminate all attacker footholds.

Activities:

1. **Root Cause Analysis:** Identify the attack vector, vulnerabilities exploited, and persistence mechanisms established by the attacker.
2. **Malware Removal:** Remove all identified malware, backdoors, web shells, and unauthorized accounts from affected systems.
3. **Vulnerability Remediation:** Patch or mitigate the vulnerabilities that enabled the incident. Coordinate with the *Vulnerability Management Program* and system owners for emergency patching.
4. **Credential Reset:** Force password resets for all compromised accounts. For Sev-1 incidents involving identity infrastructure, consider a domain-wide credential reset in coordination with the IAM team.
5. **Validation:** Conduct thorough scanning and testing of remediated systems to confirm eradication is complete. Use IOCs developed during investigation to verify no residual compromise exists.

5.4 Phase 4: Recovery

Objective: Restore affected systems and services to normal operation in a controlled manner.

Activities:

1. **Recovery Planning:** Develop a prioritized recovery plan based on business impact. Critical services (as defined in the *IT Service Continuity and Disaster Recovery Plan, 2026-OPS-04*) are restored first.
2. **System Restoration:** Rebuild or restore systems from known-good backups. Verify backup integrity before restoration. Systems restored from backup must be patched to current levels before reconnection to the network.
3. **Phased Reconnection:** Reconnect restored systems to the network in a staged manner with enhanced monitoring. The CSIRT must approve each reconnection step.
4. **User Access Restoration:** Re-enable user accounts and access permissions following verification that credentials have been reset and multi-factor authentication is properly configured per the *Identity and Access Management Policy (2026-SEC-02)*.
5. **Monitoring:** Implement heightened monitoring of recovered systems for a minimum of **30 days** following restoration. The monitoring period may be extended based on CSIRT assessment.

Recovery Validation Checklist:

- [ ] All compromised systems rebuilt or restored from verified clean backups
- [ ] All vulnerabilities exploited in the incident have been patched
- [ ] All compromised credentials have been reset
- [ ] Enhanced monitoring deployed on affected systems and network segments
- [ ] Business owners confirm system functionality and data integrity
- [ ] CSIRT Director approves return to normal operations

5.5 Phase 5: Post-Incident Activity

Objective: Document lessons learned, improve defenses, and fulfill regulatory and compliance obligations.

Post-Incident Review Meeting:

A formal post-incident review ("lessons learned") meeting is conducted within **five (5) business days** of incident closure for Sev-1 and Sev-2 incidents, and within **ten (10) business days** for Sev-3 incidents. The review is chaired by the CSIRT Director and includes all CSIRT members involved in the response, as well as relevant stakeholders from affected departments.

Review Agenda:

1. Timeline reconstruction — detailed chronology of the incident from detection through recovery
2. Root cause analysis findings and contributing factors
3. Assessment of response effectiveness — what worked well, what could be improved
4. Identification of security control gaps and recommended enhancements
5. Review of communication effectiveness — internal and external
6. Regulatory compliance assessment — were all notification obligations met?
7. Action items with assigned owners and deadlines

Post-Incident Report:

The CSIRT produces a formal Post-Incident Report within **ten (10) business days** of Sev-1 and Sev-2 incident closure. The report includes:

- Executive summary suitable for university leadership

- Technical analysis and root cause determination
- Complete incident timeline with key decision points
- Impact assessment (data, systems, users, financial, reputational)
- Remediation actions taken and their effectiveness
- Recommendations for preventing similar incidents
- Appendices: IOCs, evidence inventory, communication log

The Post-Incident Report is classified as **Level 3 (Confidential)** under the *Data Classification and Handling Policy (2026-GOV-03)* and is distributed only to authorized recipients as determined by the CSIRT Director and General Counsel.

6.0 Training and Preparedness

6.1 CSIRT Training Requirements

All CSIRT members must maintain current training and certifications relevant to their functional role. Minimum requirements include:

- **Annual incident response training** — tabletop exercises and simulated incident scenarios
- **Biannual technical training** — updated techniques in forensics, malware analysis, network defense, and threat intelligence
- **Role-specific certifications** — e.g., GCIH, GCFA, GCIA, CISSP, or equivalent as determined by the CSIRT Director
- **Regulatory training** — annual training on FERPA, HIPAA, PCI DSS, and state breach notification requirements

6.2 University-Wide Awareness

The CSIRT collaborates with the IT Security Awareness Program to ensure all university community members understand their responsibilities under this Plan:

- **New employee onboarding** includes a module on cybersecurity incident reporting procedures
- **Annual security awareness training** (required for all faculty and staff) includes incident recognition and reporting
- **Phishing simulation exercises** are conducted quarterly to assess and improve community resilience
- **Department-specific briefings** are provided to units handling Level 4 (Restricted) data, including the Bursar's Office, Financial Aid, Human Resources, and Student Health Services

6.3 Tabletop Exercises

The CSIRT conducts a minimum of **two (2) full-scale tabletop exercises per year**, simulating Sev-1 incident scenarios. These exercises involve the Extended Response Team and university leadership to test:

- Incident detection and initial response procedures
- Escalation and communication workflows
- Decision-making under pressure
- Coordination with external partners and law enforcement
- Recovery and business continuity procedures

Exercise results are documented and reviewed. Identified gaps are tracked as action items in the CSIRT's continuous improvement program.

7.0 Policy Maintenance and Review

7.1 Annual Review

This Plan is reviewed annually by the CSIRT Director in coordination with the Chief Information Officer and the University Risk Management Committee. The review assesses:

- Changes in the university's threat landscape and risk profile
- Lessons learned from incidents and exercises conducted during the review period
- Changes in regulatory requirements or industry standards
- Organizational changes affecting CSIRT membership or structure
- Technology changes affecting detection, response, or recovery capabilities

7.2 Emergency Revisions

The CSIRT Director may issue emergency revisions to this Plan outside the normal review cycle in response to:

- A significant incident that reveals critical gaps in current procedures
- New regulatory mandates with immediate compliance deadlines
- Fundamental changes in university IT infrastructure or threat environment

Emergency revisions are communicated to all stakeholders within **48 hours** of approval and are formally incorporated into the next scheduled annual revision.

8.0 Related Policies and References

Document	Policy Number
Acceptable Use Policy	2026-GOV-01
Data Classification and Handling Policy	2026-GOV-03
Identity and Access Management Policy	2026-SEC-02
IT Service Continuity and Disaster Recovery Plan	2026-OPS-04
Vendor and Third-Party Risk Management Policy	2026-GOV-05
Network Security and Architecture Standards	2026-SEC-03
NIST SP 800-61 Rev. 2	External Reference
NIST Cybersecurity Framework v2.0	External Reference

9.0 Document History

Version	Date	Author	Changes
1.0	July 1, 2019	IT Security Office	Initial release
2.0	July 1, 2020	IT Security Office	Added HIPAA and PCI DSS notification timelines
3.0	July 1, 2022	Dr. Patricia Okonkwo	Restructured severity model; added Extended Response Team
4.0	July 1, 2024	Dr. Patricia Okonkwo	Updated for NIST CSF v2.0 alignment; added CIRCIA reporting
5.0	July 1, 2026	Dr. Patricia Okonkwo	Annual review; updated contact information; enhanced recovery validation procedures

---

Synthetic document for a take-home assignment. Not an official NYU policy. | Northfield University Office of IT